

數位信任的基石：現代資訊安全架構與社會影響

從核心原則到全方位防禦對策的系統性解析



社會命脈：為何資訊安全決定了現代社會的運作

資訊安全不僅是技術議題，更是維持社會運作的基石。實施 ISO/IEC 27001 的核心目的在於：

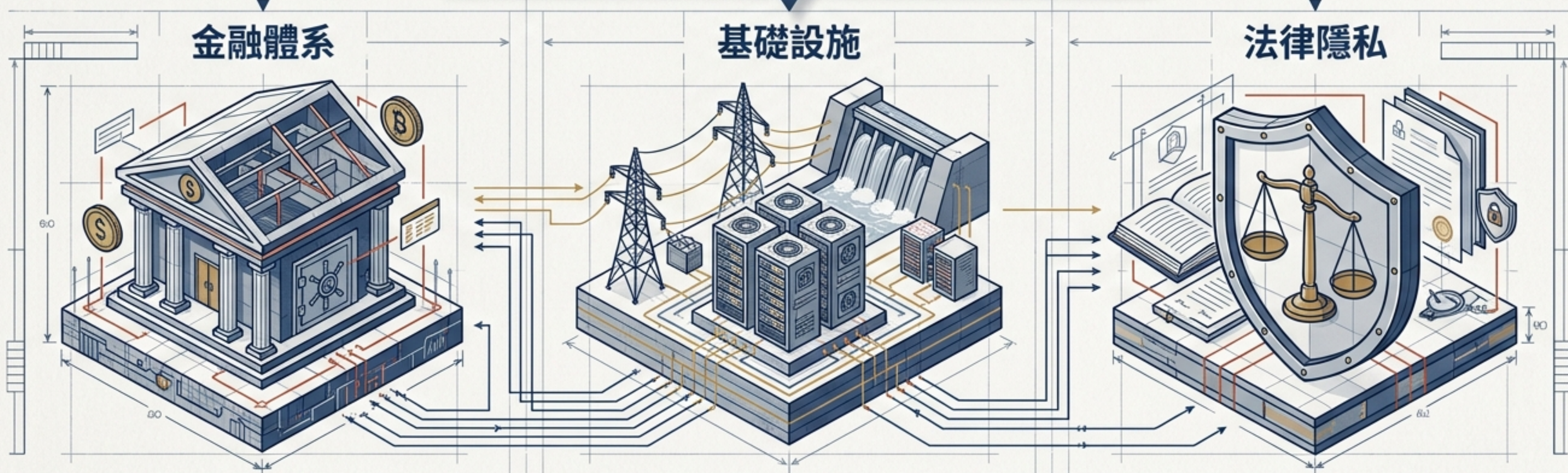
ISO/IEC 27001 核心目標

- 全員參與制度化：建立動態且以預防為主的管理體系。
- 成本效益：用最低的成本獲得較高的資訊安全。
- 終極目標：「從根本上保證業務的持續營運」。

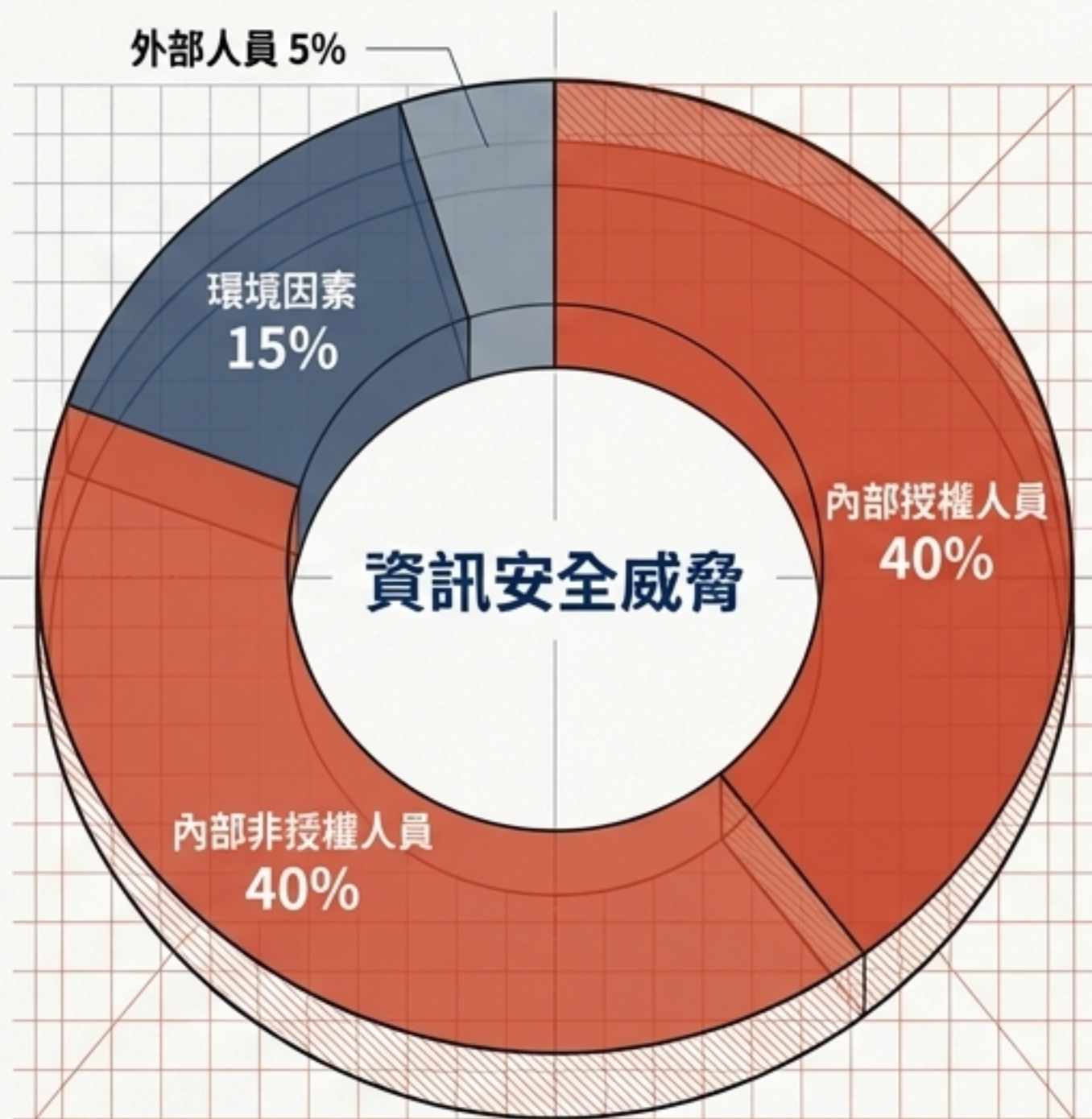
金融體系

基礎設施

法律隱私



威脅的真相：最大的風險來自「內部」



15% 環境因素

這地環境因素之外，這種會內的生物物理暨機載性及面，資訊安全威脅。



僅 5% 外部人員

包含 5% 外部人員是一部有種組織的性擊性，內部威脅所攻擊類型首位。



80% 內部人員威脅

包含 40% 內部授權人員，與 40% 內部非授權人員(人為疏失、不誠信員工)。



根據 IBM X-Force 報告，高達 60% 的攻擊事件來源與組織內部人員 (insider threats) 有關，內部威脅穩居所有攻擊類型首位。

信任的核心座標：資訊安全 CIA 三要素

機密性 (Confidentiality)

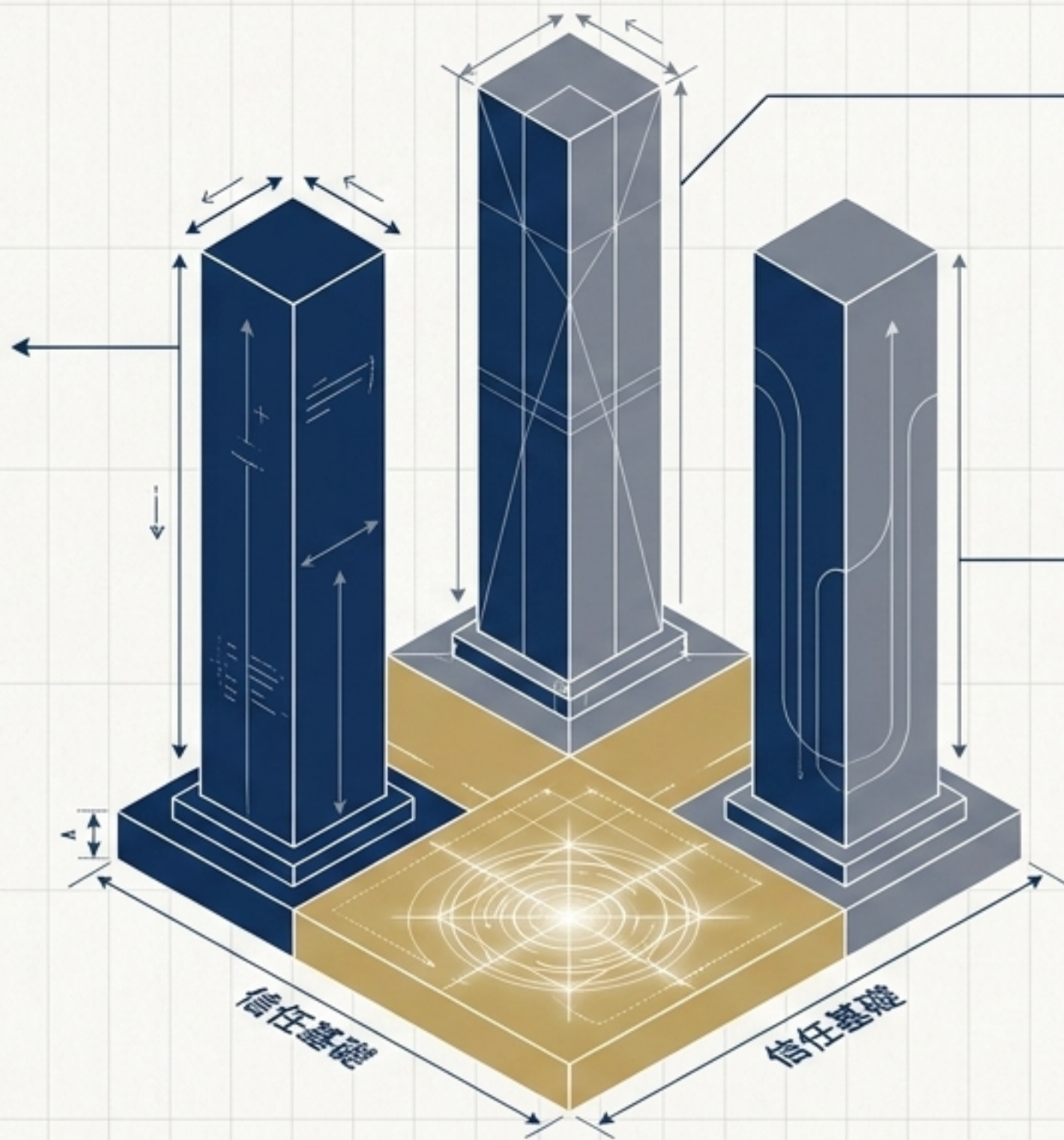
防止未授權存取。維持資訊在傳輸、儲存與處理時，不被非授權人員存取或竄改。

完整性 (Integrity)

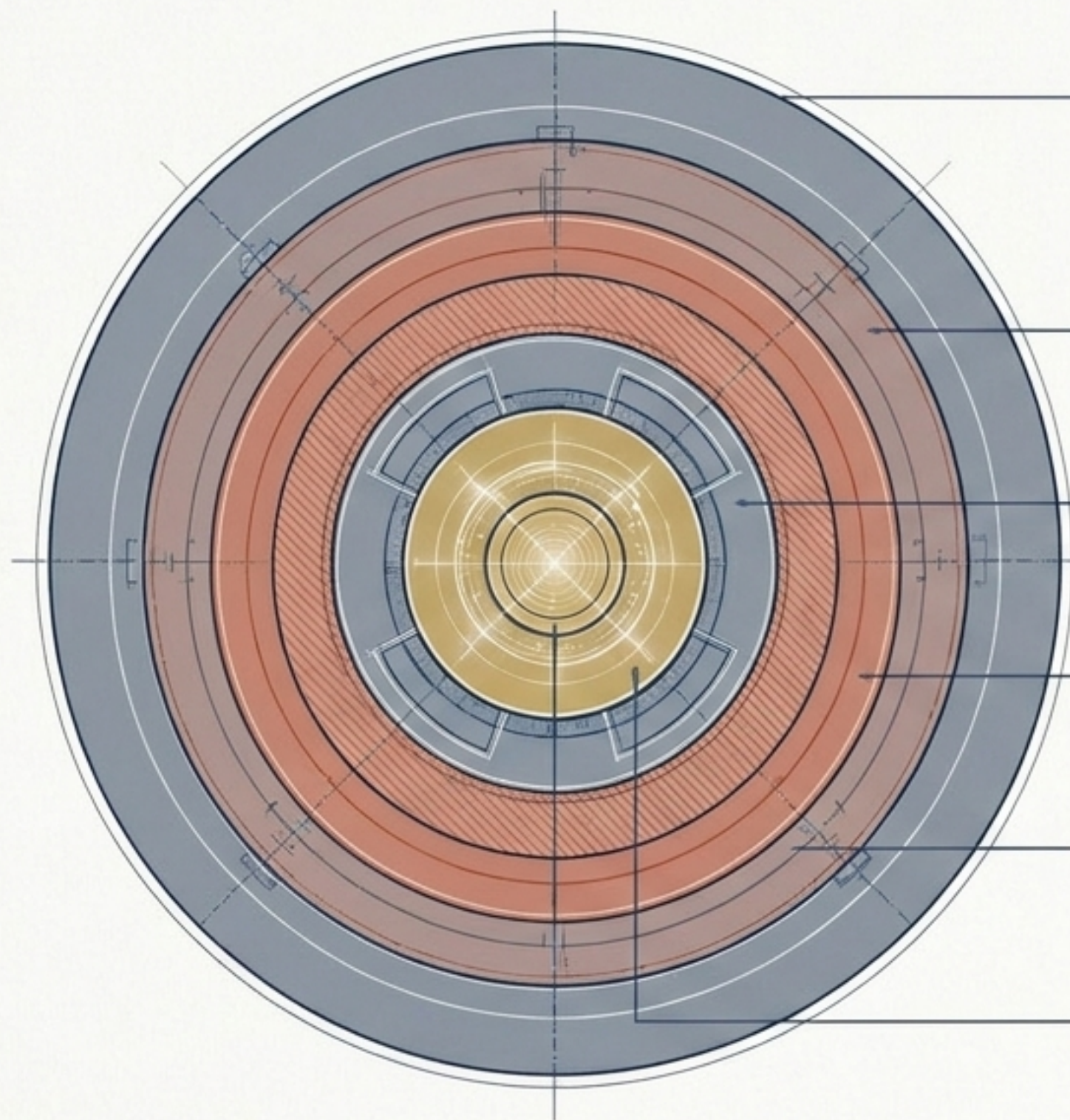
確保資料不遭竄改。具備權限者才可修改，確保資料歷經時空變化仍維持一致。

可用性 (Availability)

系統持續提供服務。合法使用者要求服務時，能在適當時間內獲得回應。



系統的深度防禦：資訊架構的六個層次



1. 外圍層 (Periphery)

電腦系統周邊外圍之環境因素
(如機房、鄰近環境)。

2. 外部層 (External)

使用者與系統間的介面。

3. 中心層 (Center)

內部層與外部層溝通的橋樑。

4. 內部層 (Internal)

資料實際儲存及管理方式。

5. 分析層 (Analysis)

系統之管理與安全威脅之分析。

6. 法律層 (Legal)

資訊安全相關的法律規範。

資訊安全的八大作戰領域

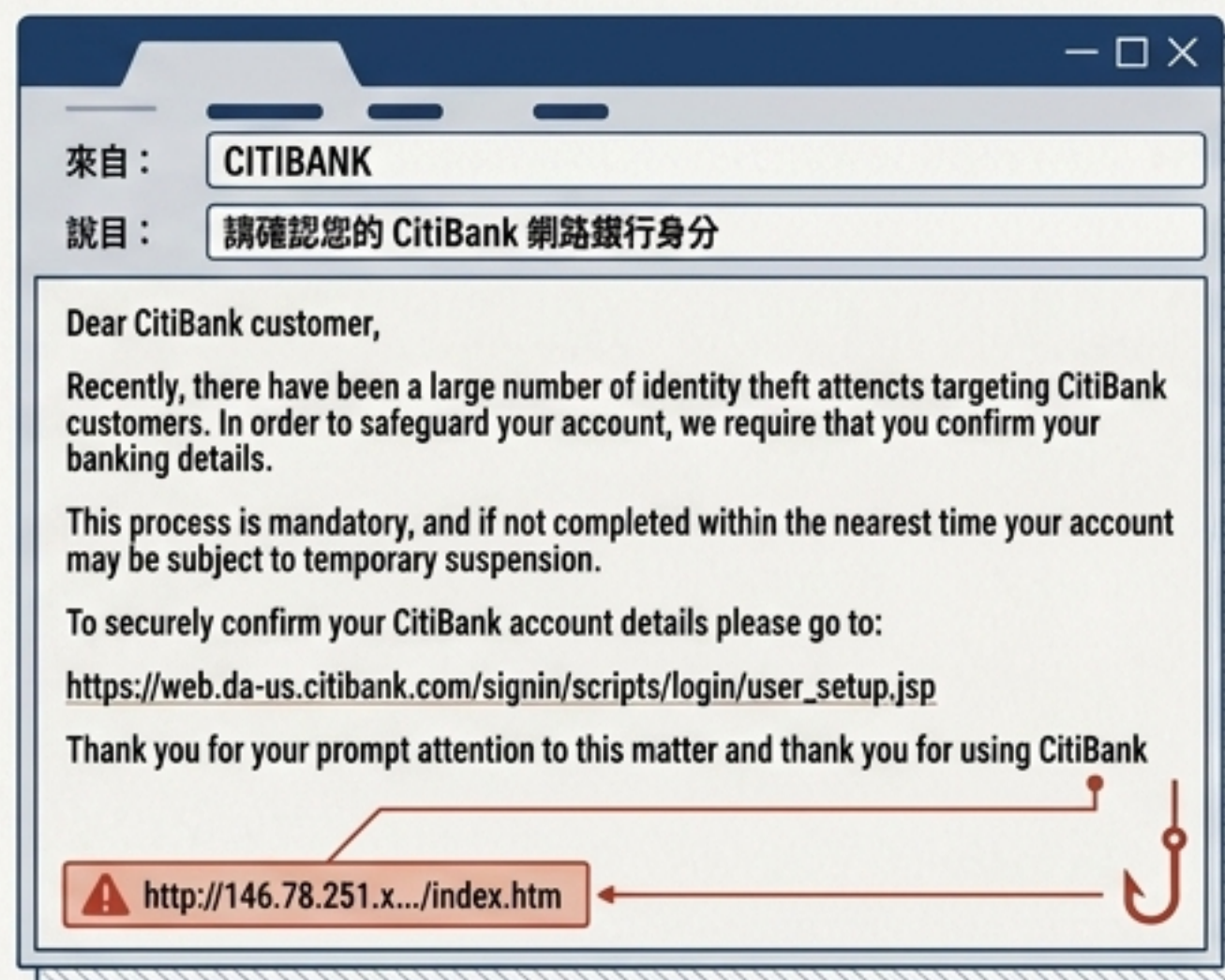
	安全暨風險管理 (Security and Risk Management)		身分識別暨存取管理 (Identity and Access Management)
	資產安全 (Asset Security)		安全性評估與測試 (Security Assessment and Testing)
	安全工程 (Security Engineering)		作業安全 (Operations Security)
	通訊及網路安全 (Communication and Network Security)		軟體開發安全 (Software Development Security)

戰術焦點 I：資產保全與身分存取

實體存取控制



社交工程與虛擬威脅



- 資產的雙面性：有形的實體資產 (建築、主機) 與無形的虛擬資產 (軟體、商譽)。
- 存取控制的防線：涵蓋管理、技術與實體面，透過權限設定保護資訊資產。
- 風險管理：針對人員或資產經濟價值的不確定性，分配有限資源以降低風險。

戰術焦點 II：網路通訊與安全工程



網路威脅三本柱

外部入侵者、內部人員惡意破壞、惡意軟體傳播。

攻擊鏈

利用系統弱點 -> 穿透防火牆 -> 植入後門 -> 作為跳板癱瘓系統或竊取資訊。

工程防護

涵蓋密碼學（資料加密）到實體機房選址（自然災害防護、電力評估）。

戰術焦點 III：從開發到持續營運



V&V 雙重把關

驗證 (Verification - 符合功能規格) 與 確認 (Validation - 符合客戶需求)。

源碼檢測

(Source Code Analysis)

驗證網頁應用程式安全，避免漏洞的最有效方法。

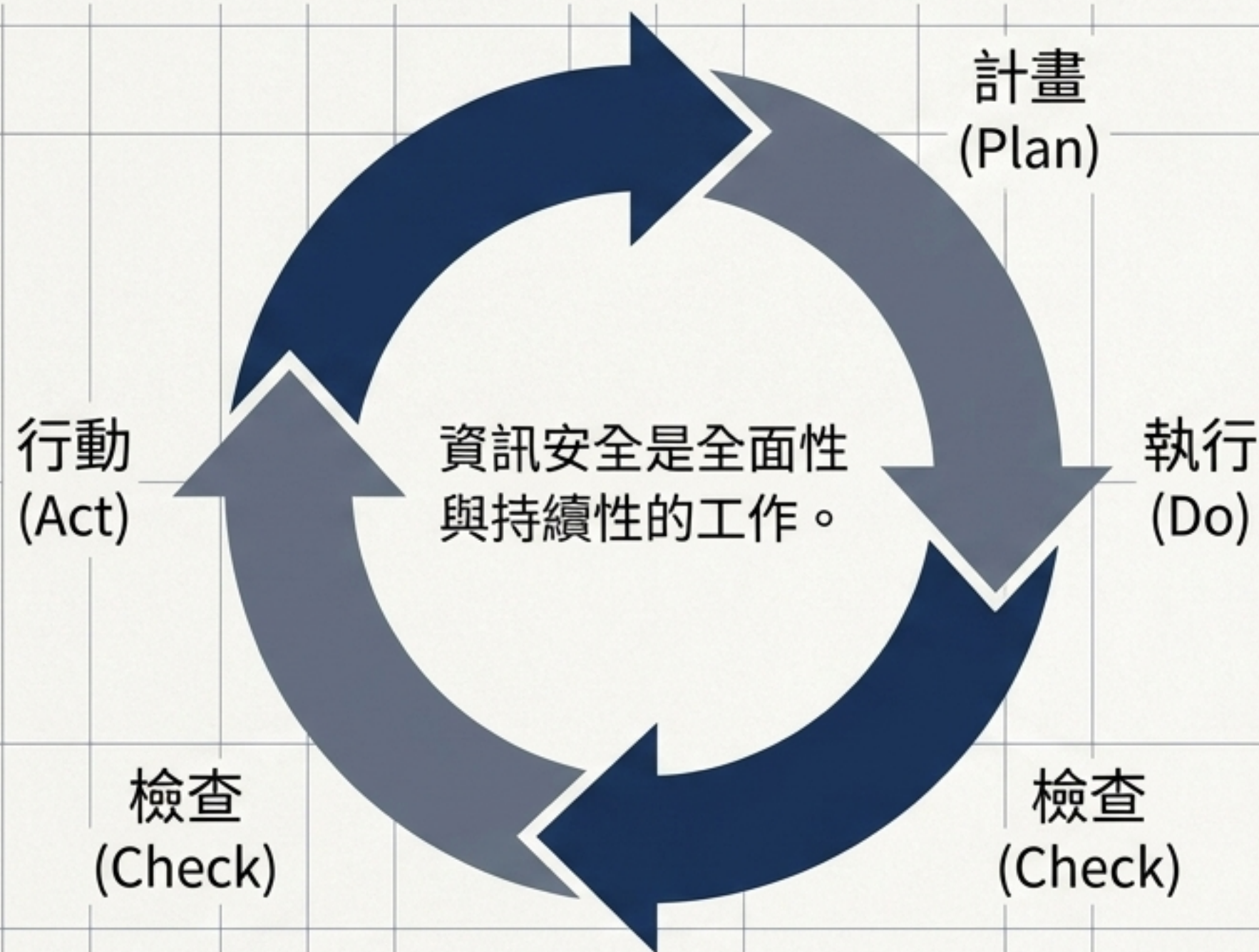
滲透測試

(Penetration Test)

具備高道德標準的團隊，以「攻擊者思維」進行安全探測，找出防護機制的隱藏弱點。

防禦的引擎：PDCA 持續改善循環

資訊安全是全面性與持續性的工作。



勤奮 (Due Diligent)

切實遵照程序，主動發現風險。



勞心 (Due Care)

落實執行各項對策，將風險降至可接受程度。

決戰矩陣：全方位防範對策統整

	防毒 (Anti-virus)	防駭 (Anti-hack)	防災 (Disaster)	防竊 (Anti-theft)
管理面	制定更新政策	人員存取規範	營運持續計畫	資產盤點管理
技術面	安裝防毒軟體	防火牆與密碼	系統資料備份	機密資料加密
實體面	禁用外接裝置	機房門禁管制	環境災害防護	設備實體上鎖

總結：建構具備韌性的資訊社會

- ✓ 數位信任無法一蹴可幾，必須建立在「管理、技術、實體」三位一體的深度防禦架構上。
- ✓ 透過 PDCA 持續優化與「勞心勤奮」的文化，我們才能以最低成本實現最高防護。
- ✓ 最終，資訊安全不僅是防禦，更是驅動現代社會持續創新與無間斷營運的最強後盾。

